

Authentication Endpoint: User Enumeration and Missing Rate Limiting

Meg Maroni

September 17, 2026

Assessment Details

Name	Meg Maroni
Email	s221193238@deakin.edu.au
Team	AppAttack PenTesting
Role	Junior Lead
Project	EVAT
Quality Assurance	Andrew Udawela
Was this Finding Successful?	Yes
Is this a Re-tested Finding?	No

Impact Values

Very Minor	Risk that holds little to no impact. Will not cause damage and regular activity can continue.
Minor	Risk that holds minor impact. Can cause some damage but not enough to significantly affect operations.
Significant	Risk that causes noticeable disruption and may impede regular activity.
Major	Risk that significantly impacts operations and prevents the system from running normally.
Severe	Risk that causes critical damage and may stop activity entirely.

Likelihood

Rare	Event may occur only in exceptional circumstances.
Unlikely	Event could occur occasionally.
Moderate	Event may occur under certain conditions.
High	Event is likely to occur often.
Certain	Event is occurring now or is expected to occur frequently.

Finding Details

Finding Name: User Enumeration via Verbose Authentication Error Messages

Description

The login endpoint returns distinct, explicit error messages depending on whether a submitted email address corresponds to a registered account. When an existing account is submitted with an incorrect password, the API responds with a message confirming the account exists (e.g. *"Authentication failed: Invalid password for email = [email.here]"*). When a non-existent email is submitted, the API instead responds with a message explicitly stating the account does not exist (e.g. *"Authentication failed: The account with email = [email.here] does not exist"*). These two response bodies also differ in length (83 bytes vs. 118 bytes in testing), providing a second, independently detectable signal even if the message text were later obscured.

This finding is closely related to a separate finding submitted by another team member, included separately within this report and is referenced here only for context, which confirms that the same `/api/auth/login` endpoint applies no rate limiting, throttling, or account lockout even after 100 consecutive failed attempts.

Risk

An attacker in possession of a list of potential email addresses (e.g. sourced from public breach data, a company staff directory, or scraped contact lists) can submit each address to the login endpoint and, purely from the response message and/or response length, determine with certainty which addresses correspond to registered accounts on this platform, without needing to guess a password.

This enumeration finding compounds directly with the missing rate limiting reported, which allows the enumeration attempts to be run at a high volume without interruption, and the resulting list of confirmed valid accounts could then be fed into an unrestricted chain of password-guessing attempts against the same endpoint. Together, the two findings significantly reduce the effort required for an attacker to identify real users and subsequently compromise their accounts via brute-force or credential-stuffing attacks. The two findings should be considered jointly when assessing overall risk to this endpoint, as this increases the severity.

Independent of the rate-limiting issue, the enumeration signal itself also enables:

- Targeted phishing campaigns against users known to hold an account on this platform.

Affected Assets

- EVAT WebApp: Authentication API (backend, Express/Node.js service)
- User account records exposed via the authentication response messages

Affected Path

POST `/api/auth/login` (backend service, `http://localhost:8080`)

Evidence

The following request/response pair was captured in Burp Suite when submitting a known, existing account email with an incorrect password:

```
HTTP/1.1 401 Unauthorized
```

```
Content-Type: application/json; charset=utf-8
```

```
Content-Length: 83
```

```
{"message":"Authentication failed: Invalid password for email = [Test1@gmail.com]"}}
```

Figure 1: Utilising the known user account (Test1@gmail.com) with an incorrect password to monitor server response.

Figure 2: Burp Suite Repeater response for a known, registered account. The server explicitly confirms the account exists.

The same request was then repeated using an email address that does not correspond to any registered account:

```
HTTP/1.1 401 Unauthorized
```

```
Content-Type: application/json; charset=utf-8
```

```
Content-Length: 118
```

```
{"message":"Authentication failed: The account with email =  
[definatly_not_a_real_email_1@gmail.com] does not exist"}
```

Figure 3: Utilising a non-registered account (definatly_not_a_real_email_1@gmail.com) to monitor server response.

Figure 4: Burp Suite Repeater response for a non-existent account. The server explicitly confirms the account does not exist, and the response length differs from the known-account case (118 bytes vs. 83 bytes).

Remediation Advice

- Return a single, generic error message for all authentication failures on both the UI and server response, regardless of whether the cause was an invalid email or an invalid password (e.g. *"Invalid email or password"*), so the two cases cannot be distinguished.

- Ensure the response time and response body length are equivalent for both the "account does not exist" and "incorrect password" cases, to remove timing- and length-based side channels in addition to the message text.
- Apply the same generic-error principle to the registration endpoint and any password-reset/"forgot password" flow, as these are common alternative locations for the same class of enumeration vulnerability.
- Rate limiting and account lockout controls for this endpoint are addressed in the separate finding *"Missing Rate Limiting on Login Endpoint Allows Unlimited Password Guessing"* (Shaharyar Nadeem); implementing both sets of remediations together is recommended, since either control alone leaves the other risk unmitigated.